REPORT DI AUDIT PRIVACY & SCHEDA DI VALUTAZIONE

URL TARGET	DATA DI ESECUZIONE	AUDITOR DI RIFERIMENTO
`https://it.shein.com`	06/11/2026	Audit Compliance GDPR / Web Privacy

1. TABELLA DI RIEPILOGO DELLE EVIDENZE E GRIGLIA DI RISCONTRO

Area di Verifica	Parametro di Controllo	Stato	Note Tecniche ed Evidenze
Infrastruttura	Attivazione e forzatura protocollo HTTPS	Conforme	Reindirizzamento automatico (301) da HTTP a HTTPS. Certificati SSL/TLS validi con cifratura aggiornata.
Consenso (Banner)	Assenza di cookie di profilazione pre-consenso	Parzialmente Conforme	Al primo accesso il banner compare, ma diversi tracker e pixel analitici/pubblicitari (es. Meta/TikTok Pixel) si inizializzano prima del click.
Consenso (Banner)	Simmetria visiva tra opzioni di accettazione e rifiuto	Non Conforme	Il pulsante "Accetta tutti" è in forte evidenza cromatica; il rifiuto richiede l'accesso a sotto-menu secondari (Dark Pattern).
Consenso (Banner)	Disponibilità di un sistema di revoca permanente	Conforme	Presente link permanente nel footer ("Impostazioni Cookie") che riapre il pannello di gestione delle preferenze.
Trasparenza (Policy)	Completezza dei dati identificativi del Titolare	Conforme	Privacy Policy recante le entità responsabili per l'UE (Roadget Business Pte. Ltd. / Infinite Styles Services Co. Ltd.) e contatti DPO.
Trasparenza (Policy)	Esplicitazione delle basi giuridiche per finalità	Conforme	La policy distingue le basi giuridiche (contratto, legittimo interesse prevenzione frodi, consenso per marketing e profilazione).
Trasparenza (Policy)	Definizione dei termini di conservazione dei dati	Parzialmente Conforme	Indicazioni generiche ("per il tempo necessario erogazione servizio"), prive di una tabella di data retention dettagliata per categoria.
Trasparenza (Policy)	Indicazione dei trasferimenti Extra-UE	Conforme	Specificato il trasferimento dei dati al di fuori del SEE (Singapore, Cina, USA) con richiamo alle Clausole Contrattuali Standard (SCC).
Raccolta Dati (Form)	Applicazione del principio di minimizzazione	Conforme	Nei form di registrazione e checkout vengono richiesti unicamente i dati necessari all'evasione dell'ordine e alla spedizione.
Raccolta Dati (Form)	Separazione e granularità dei consensi	Parzialmente Conforme	Consenso marketing/profilazione in parte associato al primo acquisto/registrazione tramite coupon promozionali.
Raccolta Dati (Form)	Assenza di meccanismi di pre-flagging	Conforme	Assenza di caselle preselezionate per l'accettazione del marketing diretto nei form di checkout standard.
Risorse Esterne	Blocco preventivo di widget e font remoti	Non Conforme	Font remoti, widget social e script analitici vengono caricati subito all'accesso senza attendere l'interazione sul banner.

2. RACCOMANDAZIONI TECNICHE E AZIONI CORRETTIVE

2.1. Banner Cookie: Eliminazione Dark Pattern e Simmetria delle Scelte

Rischio Compliance: Sanzioni EDPB/Garante Privacy per vizio di validità del consenso mediante asimmetria d'impatto visivo.

Azione Correttiva: Introdurre nel primo livello del banner un pulsante "Rifiuta Tutti" o "Continua senza accettare" avente le medesime dimensioni, forma e contrasto del tasto "Accetta Tutti", garantendo la gestione delle preferenze con un solo click.

2.2. Gestione Tracker e Blocco Preventivo Risorse Esterne

Rischio Compliance: Violazione Artt. 6 e 7 GDPR per tracciamento in assenza di preventiva base giuridica (caso Google Fonts / Cookie).

Azione Correttiva: Implementare la CMP in modalità *Prior Blocking* nativo, sospendendo l'esecuzione di Meta/TikTok Pixel, Google Analytics e font remoti fino all'opt-in. Si raccomanda altresì l'hosting locale dei Web Font su server proprietari.

2.3. Definizione dei Termini di Conservazione dei Dati (Data Retention)

Rischio Compliance: Inosservanza del principio di limitazione della conservazione ex Art. 5.1.e GDPR.

Azione Correttiva: Inserire nella Privacy Policy una tabella chiara e puntuale indicante i tempi massimi di conservazione per ciascuna tipologia di trattamento (es. Dati di vendita: 10 anni per obblighi fiscali; Dati di marketing: 24 mesi).

2.4. Granularità dei Consensi e Moduli di Raccolta Dati

Rischio Compliance: Rischio di invalidità del consenso vincolato ex Art. 7.4 GDPR (bundling di servizi e promozioni).

Azione Correttiva: Separare nettamente la creazione dell'account dalla sottoscrizione a finalità promozionali, assicurando che l'erogazione di sconti/coupon sia svincolata dall'obbligo di opt-in per la profilazione comportamentale.

3. CONCLUSIONI E PIANO DI AZIONE CORRETTIVA (REMEDIATION PLAN)

L'audit condotto sull'infrastruttura web di **SHEIN (it.shein.com)** evidenzia un livello di rischio complessivo di grado **MEDIO-ALTO**. Sebbene la piattaforma garantisca elevati standard di sicurezza infrastrutturale (protocollo HTTPS cifrato) e una corretta perimetrazione dei dati identificativi del Titolare e delle basi giuridiche operative, si riscontrano severe criticità nell'architettura di acquisizione del consenso e nella gestione delle risorse esterne. La prioritizzazione dei rischi impone l'immediata risoluzione di due non conformità critiche: l'impiego di *dark patterns* cromatici e strutturali nel banner cookie (che negano la necessaria simmetria tra accettazione e rifiuto) e il mancato blocco preventivo di script di profilazione di terze parti e font remoti al primo caricamento pagina. A queste si affiancano criticità di secondaria gravità relative alla genericità dei tempi di Data Retention in policy e all'eventuale condizionamento dei consensi mediante incentivi promozionali. Per raggiungere la piena conformità al GDPR e alle Linee Guida EDPB/Garante Privacy, si propone una remediation articolata in due fasi correlate: **1) Intervento Tecnico immediato:** configurazione del blocco preventivo mediante CMP lato server o tag manager, migrazione dei font su server proprietari e restyling dell'interfaccia utente con il tasto "Rifiuta Tutti" a pari evidenza cromatico-visiva; **2) Intervento Legale e Documentale:** integrazione della Privacy Policy con una tabella analitica di retention per categoria di dato e revisione dei form di registrazione per garantire la piena granularità e libertà del consenso promozionale.